UNDERSTAND CONDITIONAL ACCESS POLICIES USING MICROSOFT ENDPOINT MANAGER

- Presented by Team A

INTRODUCTION TO CONDITIONAL ACCESS

- Conditional Access is Microsoft's identity-driven control mechanism

- Provides context-based security beyond usernames & passwords

- Acts as the 'gatekeeper' to apps, data, and corporate resources

- Works by evaluating identity signals, device health, and risk levels

- Critical in preventing phishing, credential theft, and ransomware attacks

- Replaces static security models with adaptive enforcement policies

HOW CONDITIONAL ACCESS WORKS

- - Operates as a decision engine after primary authentication
- - Evaluates real-time conditions: user, device, app, location, risk
- - Policies use If-Then logic (If condition = met, Then grant/restrict)
- - Possible outcomes:
    - Grant access
    - Block access
    - Require MFA
    - Apply session restrictions
- - Balances productivity with strong security controls
- - Policies are applied seamlessly without disrupting the user experience

KEY COMPONENTS OF CONDITIONAL ACCESS

- - Assignments:
    - Users and Groups
    - Cloud Apps or Actions
- • Conditions like device, risk, and location
- - Access Controls:
    - Grant controls (MFA, compliant device, hybrid join)
    - Session controls (download restrictions, limited access)
- - Enforcement ensures only trusted users and devices access resources
- - Works consistently across Microsoft 365, Azure, and integrated SaaS apps

SIGNALS EVALUATED BY CONDITIONAL ACCESS

- - Identity Signals:
    - User roles (admin, employee, vendor)
    - Group memberships
- -Device Signals:
    - Device compliance with Intune policies
    - OS version and patch status
- Location Signals:
    - Named locations (trusted offices)
    - IP address ranges
- Risk Signals:
    - User risk (compromised credentials)
    - Sign-in risk (suspicious activity)
- Application Context:
    - SaaS, Microsoft 365, custom apps
- Real-time assessment ensures adaptive security decisions

CONDITIONAL ACCESS IN MICROSOFT ENDPOINT MANAGER

- Integrated with Azure Active Directory (AAD)
- Works with Intune to enforce compliance and enrollment policies
- Ensures access only from secure, managed devices
- Protects Microsoft 365 workloads (Outlook, Teams, SharePoint)
- Extends to 3rd-party applications via Azure AD federation
- Supports hybrid organizations (cloud + on-premises)
- Provides seamless experience for end-users with transparent enforcement

USER & GROUP ASSIGNMENT

- - Assign CA policies at different levels:
    - Individual users
    - Security groups
    - Organizational units
- - Examples:
    - Require MFA for executives
    - Exclude emergency accounts to avoid lockouts
- - Best practice: Use role-based targeting for precise control
- - Ensure service accounts are excluded from strict policies

APPLICATION TARGETING

- - Target specific cloud applications:
    - Microsoft 365 apps like Teams, Outlook, OneDrive
    - SaaS apps such as Salesforce, Dropbox
    - Custom LOB apps integrated with Azure AD
- - Apply stronger controls for sensitive apps
- - Example: Allow web-only access for SharePoint on unmanaged devices
- - Extend security to both first-party and third-party resources

DEVICE-BASED CONDITIONS

- - Policies can enforce device compliance:
    - Require Intune-enrolled or domain-joined device
    - Enforce encryption and password requirements
    - Restrict access from outdated OS versions
- - Support across platforms:
    - Windows 10/11, macOS, iOS, Android
- - BYOD Scenarios:
    - Read-only or web-only access for personal devices
- - Enhances security without blocking productivity

GRANT CONTROLS

Define	- Define access requirements based on conditions: • Require Multi-Factor Authentication (MFA) • Require compliant device with Intune • Require device to be Hybrid Azure AD joined • Enforce approved client apps
Block	- Block access completely if high-risk detected
Combine	- Combine multiple controls with AND/OR logic for flexibility
Require	- Example: Require MFA + compliant device for external access

SESSION CONTROLS

- - Provide fine-grained restrictions within user sessions:
    - Restrict file downloads in SharePoint or OneDrive
    - Block copy/paste or print operations in browser
    - Enforce limited session timeouts
    - Require re-authentication after certain period
- - App-enforced restrictions integrate with Microsoft apps (Outlook, Teams)
- - Protects sensitive data without fully blocking access
- - Supports real-time risk-based adjustments

EXAMPLES OF ACCESS CONTROLS IN ACTION

- Example 1: Require MFA for all logins outside corporate network
- Example 2: Block access from high-risk geographies
- Example 3: Allow browser-only access for unmanaged BYOD devices
- Example 4: Block downloads of sensitive files from SharePoint
- Example 5: Enforce stronger controls when user risk = High
- Example 6: Limit contractors to specific applications only
- Demonstrates flexible, scenario-based enforcement

ROLE IN ZERO TRUST SECURITY

- - Conditional Access is core to Microsoft's Zero Trust strategy:
    - Verify explicitly every time (user, device, app, location)
    - Enforce least-privilege access
    - Assume breach and continuously monitor
- - Provides adaptive security posture
- - Eliminates over-reliance on passwords
- - Ensures secure productivity for remote and hybrid workforces
- - Helps organizations align with regulatory frameworks

INTEGRATION WITH MICROSOFT DEFENDER

- - Integrates with Microsoft Defender for Endpoint (MDE)
- - Automatically blocks compromised or non-compliant devices
- - Uses real-time telemetry for risk-based Conditional Access
- - Example: Device with malware infection → access blocked until remediation
- - Automated enforcement reduces response time for threats
- - Strengthens defense against ransomware, phishing, and advanced threats

REAL-WORLD SCENARIOS

- - Remote Workforce:
- • Enforce MFA for all remote logins
- • Allow only Intune-managed devices for corporate apps
- - Healthcare:
- • Restrict access to patient records to compliant devices only
- • Enforce session restrictions on BYOD
- - Education:
- • Apply BYOD-friendly policies for students
- • Restrict data exfiltration from school apps
- - Finance:
- • Block high-risk sign-ins from untrusted locations
- • Require MFA for all financial transactions

BEST PRACTICES FOR CONDITIONAL ACCESS

Start	- Start with Report-Only mode to assess impact
Define	- Define exclusions (admin, emergency accounts)
Use	- Use layered security: MFA + compliance + location
Apply	- Apply least privilege and role-based access
Review	- Regularly review logs and reports for fine-tuning
Test	- Test policies with pilot groups before global rollout
Educate	- Educate users about MFA and security awareness
Maintain	- Maintain multiple break-glass accounts for emergencies

CHALLENGES & CONSIDERATIONS

- - Common Challenges:
    - Complexity in managing multiple policies
    - Risk of user lockouts if misconfigured
    - Balancing security with user productivity
- - Licensing requirements:
    - Azure AD Premium P1 or P2 needed
- - Considerations:
    - Continuous monitoring and updates required
    - Proper communication and change management essential
    - Need for skilled IT staff to manage policies effectively

CONCLUSION

- - Conditional Access = Adaptive Security for Modern Workplaces
- - Protects apps, data, and users with context-aware policies
- - Central to implementing Zero Trust alongside MEM + Azure AD
- - Enables secure remote work and BYOD adoption
- - Ensures compliance with regulations while maintaining productivity